



Auftrags- verarbeitungsvertrag

Dieser Auftragsverarbeitungsvertrag (nachfolgend „AVV“) konkretisiert die datenschutzrechtlichen Pflichten der Parteien im Rahmen der Nutzung der Software „Vela / Agentur OS“. Er wird geschlossen zwischen

AUFTRAGGEBER · VERANTWORTLICHER

Name der Agentur / des Unternehmens

Vertreten durch (Name, Funktion)

Anschrift (Straße, PLZ, Ort)

– nachfolgend „Auftraggeber“ oder „Verantwortlicher“ genannt –

und

AUFTRAGNEHMER · AUFTRAGSVERARBEITER

Vor- und Nachname / Firma

Produkt: Vela / Agentur OS

Anschrift (Straße, PLZ, Ort)

– nachfolgend „Auftragnehmer“ oder „Auftragsverarbeiter“ genannt –

Der Auftraggeber verarbeitet mithilfe der Software personenbezogene Daten und ist hierfür datenschutzrechtlich Verantwortlicher. Der Auftragnehmer verarbeitet diese Daten ausschließlich weisungsgebunden im Auftrag des Auftraggebers. Dieser AVV regelt die Rechte und Pflichten der Parteien gemäß Art. 28 DSGVO.

§ 1 Gegenstand, Dauer und Spezifizierung der Verarbeitung

(1) Gegenstand des Auftrags ist die Verarbeitung personenbezogener Daten durch den Auftragnehmer im Rahmen der Bereitstellung und des Betriebs der Software „Vela / Agentur OS“ (SaaS) für den Auftraggeber.

(2) Die Dauer dieses AVV richtet sich nach der Laufzeit des zugrunde liegenden Nutzungs- bzw. Test-/Pilotverhältnisses und endet mit dessen Beendigung. Die Pflichten zur Löschung und Rückgabe (§ 9) bestehen über das Vertragsende hinaus fort.

(3) Art, Umfang, Zweck der Verarbeitung, die Art der personenbezogenen Daten sowie die Kategorien betroffener Personen ergeben sich aus § 2 und werden in Anlage 1 nicht abschließend konkretisiert.

§ 2 Art der Daten und Kategorien betroffener Personen

(1) Im Rahmen der Nutzung werden insbesondere folgende Arten personenbezogener Daten verarbeitet:

- a) Stammdaten (Name, Anschrift, Kontaktdaten) von Mitarbeitenden des Auftraggebers und dessen Kunden;
- b) Projekt-, Aufgaben- und Zeiterfassungsdaten, Leistungs- und Tätigkeitsnachweise;
- c) Kalkulations-, Angebots-, Rechnungs- und Abrechnungsdaten;
- d) Kalender- und Termindaten sowie ggf. damit verbundene Kommunikationsdaten;
- e) Zugangs-, Nutzungs- und Protokolldaten der Software.

(2) Kategorien betroffener Personen sind insbesondere:

- a) Mitarbeitende, Geschäftsführung und freie Mitarbeitende des Auftraggebers;
- b) Kunden, Interessenten und Ansprechpartner des Auftraggebers;
- c) sonstige Geschäftspartner, deren Daten der Auftraggeber in der Software verarbeitet.

(3) Zweck der Verarbeitung ist ausschließlich die Erbringung der vertraglich vereinbarten Software-Leistungen. Eine Verarbeitung zu eigenen Zwecken des Auftragnehmers findet nicht statt.

§ 3 Weisungsgebundenheit

(1) Der Auftragnehmer verarbeitet personenbezogene Daten ausschließlich im Rahmen der getroffenen Vereinbarungen und nach dokumentierter Weisung des Auftraggebers, es sei denn, er ist gesetzlich zur Verarbeitung verpflichtet. In diesem Fall teilt er dem Auftraggeber diese rechtlichen Anforderungen vor der Verarbeitung mit, soweit dies rechtlich zulässig ist.

(2) Weisungen werden in der Regel in Textform erteilt. Mündliche Weisungen sind unverzüglich in Textform zu bestätigen.

(3) Ist der Auftragnehmer der Ansicht, dass eine Weisung gegen datenschutzrechtliche Vorschriften verstößt, hat er den Auftraggeber unverzüglich darauf hinzuweisen. Er ist berechtigt, die Durchführung der betreffenden Weisung bis zu deren Bestätigung oder Änderung auszusetzen.

§ 4 Technische und organisatorische Maßnahmen (TOM)

(1) Der Auftragnehmer trifft die nach Art. 32 DSGVO erforderlichen technischen und organisatorischen Maßnahmen, um ein dem Risiko angemessenes Schutzniveau zu gewährleisten. Die aktuell getroffenen Maßnahmen sind in Anlage 1 beschrieben.

(2) Die Maßnahmen können im Verlauf des Vertragsverhältnisses fortentwickelt und angepasst werden, dürfen das vereinbarte Schutzniveau jedoch nicht unterschreiten. Wesentliche Änderungen sind zu dokumentieren.

§ 5 Unterauftragsverarbeiter

(1) Der Auftraggeber stimmt dem Einsatz der in Anlage 2 genannten Unterauftragsverarbeiter zu. Diese werden insbesondere für Hosting und Infrastruktur eingesetzt.

(2) Eine Änderung oder Hinzunahme weiterer Unterauftragsverarbeiter ist zulässig, sofern der Auftragnehmer den Auftraggeber rechtzeitig vorab informiert und der Auftraggeber nicht innerhalb einer angemessenen Frist aus wichtigem datenschutzrechtlichem Grund widerspricht.

(3) Der Auftragnehmer verpflichtet die Unterauftragsverarbeiter vertraglich auf ein Datenschutzniveau, das diesem AVV entspricht. Erfolgt eine Verarbeitung in einem Drittland, stellt der Auftragnehmer geeignete Garantien nach Art. 44 ff. DSGVO sicher (z. B. EU-Standardvertrags-klauseln).

§ 6 Unterstützung des Verantwortlichen / Betroffenenrechte

(1) Der Auftragnehmer unterstützt den Auftraggeber im Rahmen seiner Möglichkeiten bei der Erfüllung der Rechte betroffener Personen (Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit, Widerspruch) sowie bei Datenschutz-Folgenabschätzungen und vorherigen Konsultationen nach Art. 35, 36 DSGVO.

(2) Wendet sich eine betroffene Person unmittelbar an den Auftragnehmer, leitet dieser das Anliegen unverzüglich an den Auftraggeber weiter und beantwortet es nicht selbst.

§ 7 Meldung von Verletzungen des Schutzes personenbezogener Daten

(1) Der Auftragnehmer meldet dem Auftraggeber jede ihm bekannt gewordene Verletzung des Schutzes personenbezogener Daten unverzüglich, spätestens jedoch innerhalb von 48 Stunden nach Kenntnis.

(2) Die Meldung enthält mindestens eine Beschreibung der Art der Verletzung, die betroffenen Datenkategorien, die wahrscheinlichen Folgen sowie die ergriffenen bzw. vorgeschlagenen Maßnahmen. Der Auftragnehmer unterstützt den Auftraggeber bei dessen Melde- und Benachrichtigungspflichten nach Art. 33, 34 DSGVO.

§ 8 Kontrollrechte und Nachweise

(1) Der Auftragnehmer stellt dem Auftraggeber alle erforderlichen Informationen zum Nachweis der Einhaltung der Pflichten aus Art. 28 DSGVO zur Verfügung und ermöglicht Überprüfungen.

(2) Kontrollen erfolgen mit angemessener Vorankündigung, während der üblichen Geschäftszeiten und ohne vermeidbare Störung des Betriebsablaufs. Der Nachweis kann auch durch geeignete Zertifikate, Testate oder Berichte unabhängiger Dritter geführt werden.

§ 9 Löschung und Rückgabe nach Beendigung

(1) Nach Abschluss der Verarbeitungstätigkeiten löscht der Auftragnehmer nach Wahl des Auftraggebers sämtliche personenbezogenen Daten oder gibt sie zurück, sofern keine gesetzliche Aufbewahrungspflicht besteht.

(2) Bestehende Sicherungskopien werden im Rahmen der regulären Backup-Zyklen gelöscht. Die Löschung ist dem Auftraggeber auf Verlangen in Textform zu bestätigen.

§ 10 Haftung und Schlussbestimmungen

(1) Für die Haftung gelten die gesetzlichen Bestimmungen, insbesondere Art. 82 DSGVO. Im Verhältnis der Parteien gehen die Regelungen des zugrunde liegenden Hauptvertrags vor, soweit dieser AVV keine abweichende Regelung trifft.

(2) Bei Widersprüchen zwischen diesem AVV und sonstigen Vereinbarungen gehen die Regelungen dieses AVV in datenschutzrechtlichen Fragen vor.

(3) Änderungen und Ergänzungen bedürfen der Textform. Es gilt das Recht der Bundesrepublik Deutschland. Sollte eine Bestimmung unwirksam sein, bleibt die Wirksamkeit der übrigen Bestimmungen unberührt.

UNTERSCHRIFTEN

Ort, Datum

Auftraggeber · Verantwortlicher

Name in Druckbuchstaben · Funktion

Auftragnehmer · Auftragsverarbeiter

Vela / Agentur OS · Name in Druckbuchstaben

Technische & organisatorische Maßnahmen

Nachfolgende Maßnahmen nach Art. 32 DSGVO gewährleisten ein dem Risiko angemessenes Schutzniveau. Sie spiegeln den aktuellen Stand wider und werden fortlaufend überprüft.

Vertraulichkeit

- Mandantentrennung: jede Agentur erhält eine logisch getrennte Datenbasis (Multi-Tenant-Architektur mit zeilenbasierter Zugriffskontrolle / Row Level Security).
- Zugriffskontrolle: rollenbasierte Rechte, individuelle Benutzerkonten, keine geteilten Zugänge.
- Verschlüsselung sensibler Zugangsdaten (z. B. Kalender-Tokens) mit AES-256-GCM in der Datenbank.
- Transportverschlüsselung (TLS/HTTPS) für sämtliche Verbindungen.

Integrität & Verfügbarkeit

- Regelmäßige automatisierte Backups; Wiederherstellbarkeit der Daten.
- Betrieb auf Infrastruktur etablierter Anbieter mit anerkannten Sicherheitszertifizierungen (siehe Anlage 2).
- Protokollierung sicherheitsrelevanter Vorgänge (Audit-Log) im Administrationsbereich.
- Trennung von Test-/Pilot- und Produktivumgebung, soweit eingesetzt.

Belastbarkeit & Verfahren

- Verfahren zur regelmäßigen Überprüfung, Bewertung und Evaluierung der Wirksamkeit der Maßnahmen.
- Verpflichtung der eingesetzten Personen auf Vertraulichkeit.
- Datenminimierung: Erhebung nur der für den Zweck erforderlichen Daten.

Hinweis: Diese Aufstellung ist vor produktivem Einsatz an den tatsächlichen technischen Stand und das gewählte Hosting-Setup anzupassen.

Genehmigte Unterauftragsverarbeiter

Der Auftragnehmer setzt zum Zeitpunkt des Vertragsschlusses folgende Unterauftragsverarbeiter ein. Der Auftraggeber stimmt deren Einsatz gemäß § 5 zu.

Supabase

Datenbank-Hosting (PostgreSQL), Authentifizierung und Realtime-Infrastruktur. Leistung: Speicherung und Bereitstellung der Anwendungsdaten.

Hosting-Region und Auftragsverarbeitungsvereinbarung des Anbieters vor produktivem Einsatz prüfen (EU-Region wählen).

Vercel

Hosting und Auslieferung der Webanwendung (Frontend/Serverless-Funktionen). Leistung: Betrieb der Anwendung.

Hosting-Region und Auftragsverarbeitungsvereinbarung des Anbieters vor produktivem Einsatz prüfen.

Optionale, vom Nutzer ausgelöste Dienste

Bei aktiver Kalender-Synchronisation: Google bzw. Microsoft (nur wenn der Auftraggeber die Verbindung selbst einrichtet). Diese Verarbeitung erfolgt auf ausdrückliche Veranlassung des Auftraggebers.

WEITERE UNTERAUFTRAGSVERARBEITER (MANUELL ERGÄNZEN)

Name · Leistung · Hosting-Region

Name · Leistung · Hosting-Region